

E-COMMERCE PLATFORM DEVSECOPS SECURITY INVESTIGATION REPORT

Comprehensive report covering all eight investigation questions with detailed explanations, tables, examples, recommendations, and presentation notes.

Background

ShopNow is a fast-growing e-commerce platform processing thousands of customer orders daily. To accelerate releases, developers deploy directly to production, peer reviews are skipped, secure coding standards are not enforced, third-party payment providers are integrated rapidly, and vulnerability assessments occur only after incidents. This creates a large attack surface affecting authentication, authorization, session management, APIs, payment processing, and customer data. The following investigation evaluates risks, vulnerabilities, cyber threats, DevSecOps adoption, OWASP best practices, business impact, and recommendations.

1. Security Risks

- ☐ **Weak Authentication:** Passwords alone, weak password policies, and lack of MFA allow attackers to compromise accounts through brute force and credential stuffing. This results in unauthorized purchases, account takeover, and loss of trust.
- ☐ **Poor Session Management:** Improper cookie handling, predictable session IDs, and missing timeout mechanisms allow session hijacking. Attackers can continue using authenticated sessions even after users log out.
- ☐ **Direct Deployment to Production:** Skipping peer review and testing allows insecure code into production. Small coding mistakes become exploitable vulnerabilities affecting thousands of users.

- ❑ **Lack of Secure Coding Standards:** Developers may fail to validate inputs, sanitize outputs, or protect secrets, increasing SQL Injection, XSS, and authentication flaws.
- ❑ **Third-Party Payment Risk:** External vendors may introduce insecure APIs or outdated software. A weakness in one provider can expose payment information.
- ❑ **Delayed Vulnerability Assessment:** Waiting until after incidents means attackers exploit weaknesses before the organization detects them. Recovery becomes more expensive than prevention.
- ❑ **Insufficient Monitoring:** Without centralized logging and security monitoring, malicious activities remain unnoticed, delaying containment and forensic investigation.

Summary: Collectively these risks threaten confidentiality, integrity, availability, customer confidence, legal compliance, and revenue.

2. Vulnerabilities with Severity

Vulnerability	Severity	Description	Mitigation
Broken Authentication	High	Weak login controls and missing MFA.	Strong passwords, MFA.
Broken Access Control	High	Users access unauthorized resources.	RBAC, least privilege.
SQL Injection	High	Unsanitized input manipulates database.	Parameterized queries.
Cross-Site Scripting	High	Injected scripts steal sessions.	Output encoding, CSP.
Insecure Session Management	High	Cookies/session IDs exposed.	Secure cookies, timeout.

High vulnerabilities require immediate remediation because they directly expose customer accounts and payment information.

3. Cyber Threats and Impact

- ☐ Credential Stuffing: Definition, attack method, impact on ShopNow, customer impact, financial loss, operational disruption, and recommended preventive controls should be considered during risk management.
- ☐ Phishing: Definition, attack method, impact on ShopNow, customer impact, financial loss, operational disruption, and recommended preventive controls should be considered during risk management.
- ☐ SQL Injection: Definition, attack method, impact on ShopNow, customer impact, financial loss, operational disruption, and recommended preventive controls should be considered during risk management.
- ☐ Cross-Site Scripting (XSS): Definition, attack method, impact on ShopNow, customer impact, financial loss, operational disruption, and recommended preventive controls should be considered during risk management.
- ☐ Distributed Denial of Service (DDoS): Definition, attack method, impact on ShopNow, customer impact, financial loss, operational disruption, and recommended preventive controls should be considered during risk management.
- ☐ Ransomware: Definition, attack method, impact on ShopNow, customer impact, financial loss, operational disruption, and recommended preventive controls should be considered during risk management.
- ☐ Malware: Definition, attack method, impact on ShopNow, customer impact, financial loss, operational disruption, and recommended preventive controls should be considered during risk management.
- ☐ API Abuse: Definition, attack method, impact on ShopNow, customer impact, financial loss, operational disruption, and recommended preventive controls should be considered during risk management.
- ☐ Insider Threat: Definition, attack method, impact on ShopNow, customer impact, financial loss, operational disruption, and recommended preventive controls should be considered during risk management.

- Man-in-the-Middle Attack: Definition, attack method, impact on ShopNow, customer impact, financial loss, operational disruption, and recommended preventive controls should be considered during risk management.

4. DevOps vs DevSecOps

Aspect	DevOps	DevSecOps
Goal	Fast delivery	Fast and secure delivery
Security	End stage	Integrated throughout SDLC
Code Review	Sometimes skipped	Mandatory
Testing	Functional	Functional + Security
Automation	CI/CD	Secure CI/CD
Compliance	Separate	Continuous
Monitoring	Performance	Performance + Security
Culture	Dev & Ops	Everyone responsible
Risk	Higher	Reduced
Cost	Lower initially	Lower long-term
Outcome	Rapid releases	Reliable secure releases

DevSecOps embeds security from planning to deployment using automated scanning, secure coding, code review, threat modeling, dependency scanning, and continuous monitoring.

5. Five OWASP Best Practices

- ☐ Implement Multi-Factor Authentication to strengthen user verification.
- ☐ Validate and sanitize all user inputs to prevent SQL Injection and XSS.
- ☐ Apply least-privilege access control using role-based authorization.
- ☐ Encrypt sensitive information in transit (HTTPS/TLS) and at rest.
- ☐ Perform continuous security testing using SAST, DAST, dependency scanning, penetration testing, and regular patch management.

6. Business Impact

- ☐ Financial losses from fraud and recovery.
- ☐ Loss of customer trust and reduced sales.
- ☐ Legal penalties for privacy violations.
- ☐ Operational downtime during attacks.
- ☐ Brand reputation damage.
- ☐ Higher incident response costs.
- ☐ Competitive disadvantage.
- ☐ Loss of business partners and investor confidence.

7. Concept Map



8. Five-Minute Presentation

- ☐ Slide 1: Introduction, ShopNow background, objectives.
- ☐ Slide 2: Security risks with real examples.
- ☐ Slide 3: Vulnerabilities, severity classification, cyber threats.
- ☐ Slide 4: DevOps vs DevSecOps comparison and OWASP practices.
- ☐ Slide 5: Business impact, concept map, recommendations, conclusion,

Q&A.

Conclusion

ShopNow should adopt DevSecOps immediately by integrating security into every software development phase. Mandatory code reviews, automated security testing, secure coding standards, continuous monitoring, employee awareness, and OWASP best practices will significantly reduce cyber risks, improve compliance, enhance customer trust, and protect business growth.

References

- ☐ OWASP Top 10
- ☐ NIST Cybersecurity Framework
- ☐ OWASP ASVS
- ☐ Microsoft Secure Development Lifecycle
- ☐ Google DevSecOps Guide
- ☐ Recent IEEE Cybersecurity Literature